

ERP/1: Авторизація

Техноробочий проект

на створення та впровадження модуля «Служба
ідентифікації та авторизації (IAS)» як засобу
інформатизації

Згідно з ДСТУ 34.201-89 та Постановою КМУ № 205 від 21.02.2025
Формалізація вимог за стандартом ISO/IEC/IEEE 29148:2018

Зміст

Зміст

1	Загальні відомості про засіб інформатизації	2
1.1	Найменування та підстави для розробки	2
1.2	Статуси опису реалізації	2
1.3	Простежуваність вимог та відповідність нормативній базі	2
1.4	Призначення та цілі створення засобу	3
1.5	Послідовність виконання наступних робіт	3
2	Відомості про робочий процес та умови експлуатації	5
2.1	Опис бізнес-процесів (BPMN / FSM)	5
2.1.1	Поточний процесний контур	5
2.1.2	Фактична модульна архітектура	5
2.2	Опис ролей та прав доступу (ABAC)	6
2.3	Умови експлуатації та системне середовище	7
3	Інформаційне та програмне забезпечення	8
3.1	Інформаційне забезпечення (Схеми та Дані)	8
3.1.1	Визначення структур даних (Erlang Records)	8
3.1.2	Опис довідників та реєстрових сутностей	9
3.1.3	Алгоритми оцінки статусу довіри (Trust Evaluation)	9
3.2	Програмне забезпечення (Реалізація)	10
3.2.1	Цільова інтеграція з BPE	10
3.2.2	Модулі перевірки CSR і сертифікатів	10
4	Вимоги до засобу за ISO/IEC/IEEE 29148	11
4.1	Функціональні вимоги	11
4.2	Вимоги до інтерфейсів та дизайну	11
4.3	Вимоги до безпеки та захисту інформації	11
4.4	Вимоги до продуктивності та надійності	11
4.5	Вимоги до логування та аудиту	11
4.6	Адміністративні та юридичні вимоги	12

1. Загальні відомості про засіб інформатизації

1.1. Найменування та підстави для розробки

Найменування засобу інформатизації: Модуль «Служба ідентифікації та авторизації (IAS)» (далі — Модуль IAS / Система IAS) у складі інформаційної системи управління підприємством ERP/1.

Підстави для розробки:

1. Закон України «Про захист інформації в інформаційно-телекомунікаційних системах».
2. Постанова Кабінету Міністрів України від 29.03.2006 № 373 «Про затвердження Правил забезпечення захисту інформації в інформаційних, телекомунікаційних та інформаційно-телекомунікаційних системах».
3. Постанова Кабінету Міністрів України від 21.02.2025 № 205 «Про затвердження Порядку використання засобів інформатизації».
4. Угода про асоціацію між Україною та Європейським Союзом (в частині транскордонної взаємодії електронних довірчих послуг).
5. Технічне завдання на побудову Zencrypted інфраструктури безпеки.

1.2. Статуси опису реалізації

Щоб не змішувати фактичну реалізацію, частково завершені можливості, цільову архітектуру та нормативні наміри, у цьому документі застосовуються такі статуси:

Статус	Зміст
Реалізовано	Підтверджено поточним кодом, стійкими структурами даних і автоматизованими тестами IAS.
Частково реалізовано	Реалізовано лише для визначеного сценарію або з тимчасовими технічними залежностями.
Цільовий стан	Запланована архітектура або функція наступних ітерацій; не трактується як наявна у поточному середовищі виконання.
Нормативна вимога	Вимога законодавства, стандарту, сертифікації або організаційної політики, що потребує окремих доказів реалізації та приймання.

1.3. Простежуваність вимог та відповідність нормативній базі

Техноробочий проєкт деталізує технічні вимоги з `ias.tex` і має зберігати зв'язок між вимогою, фактичним модулем, стійкою структурою даних, автоматизованим тестом та статусом реалізації. Посилання на неіснуючі модулі, демонстраційний код або майбутню архітектуру не повинні подаватися як опис поточного стану.

На цьому етапі зафіксовано такі межі простежуваності:

- Керування доменними об'єктами: користувачі, пристрої, сертифікати, профілі безпеки, політики та VPN-сервіси зберігаються у KVS/Mnesia через доменні модулі IAS. Статус: Реалізовано.
- Майстер налаштування VPN: поточний життєвий цикл виконується спеціалізованими модулями IAS з перевітками переходів, готовності матеріалів, доставки та відновлення. Статус: Реалізовано.
- Випуск сертифікатів через CA: поточний CMP-шлях використовує зовнішній командний інтерфейс OpenSSL і є перехідним. Повне усунення запуску OpenSSL із середовища виконання IAS є цільовим станом.
- Керування процесами через BPE/BPMN: майбутнє перенесення керування станами й переходами на `synrc/bpmn`/BPE є цільовим станом; поточний майстер поки не виконується рушієм BPE.
- EST, CMC, CRL/OCSP, повний ABAC, КСЗІ та національні криптографічні алгоритми: позначаються лише як цільові або нормативні вимоги до появи окремих реалізаційних і приймальних доказів.

1.4. Призначення та цілі створення засобу

Модуль IAS є центральною адміністративно-координаційною службою для керування цифровими ідентичностями, пристроями, сертифікатами, профілями безпеки, політиками та VPN-сервісами. IAS формує бажаний стан і передає керовані конфігурації до VPN, але не бере участі у пересиланні VPN-трафіку.

Поточні та цільові цілі:

- Реалізовано: стійкий реєстр доменних об'єктів у KVS/Mnesia, граф зв'язків, перевірка CSR і X.509, покрокове налаштування пристрою, передавання конфігурацій до VPN через Erlang RPC, ревізії, контрольні суми, журналювання доставки, звіряння стану та відновлення після збоїв.
- Частково реалізовано: випуск сертифікатів через CA за CMP із зовнішнім командним інтерфейсом OpenSSL як перехідною залежністю.
- Цільовий стан: керований клієнт або адаптер CA без запуску зовнішнього OpenSSL у IAS, а також перенесення керування життєвим циклом майстра на `synrc/bpmn`/BPE зі збереженням наявних доменних модулів і перевіреної поведінки.
- Нормативна вимога: окреме підтвердження вимог КСЗІ, КЕП, криптографії за ДСТУ, захисту персональних даних та інших нормативних профілів.

1.5. Послідовність виконання наступних робіт

Календарні строки не фіксуються без окремої оцінки обсягу, ресурсів і критеріїв приймання. Роботи виконуються у такій залежній послідовності:

1. P0 — синхронізація документації: привести `ias.tex` і `ias_pro.tex` у відповідність до поточного коду та однакових статусів реалізації.
2. P1 — усунення OpenSSL із IAS: прибрати запуск зовнішнього командного інтерфейсу OpenSSL із середовища виконання IAS, зберігши CMP або інший погоджений контракт через керований клієнт чи адаптер CA.
3. P2 — стабілізація наскрізного сценарію: прогнати й стабілізувати повний життєвий цикл майстра налаштування VPN від користувача й пристрою до передавання конфігурації, повторних спроб і відновлення після збоїв.

4. P3 — опис поточного процесу: зафіксувати фактичну FSM/BPMN-модель станів, переходів, умов, помилок і завершення без розбіжностей із кодом.
5. P4 — перенесення керування на ВРЕ: поетапно зробити ВРЕ джерелом стану й переходів, залишивши майстер користувацьким інтерфейсом над процесом та зберігши доменні сервісні модулі.
6. P5 — повторна синхронізація: узгодити технічні вимоги, техноробочий проєкт, випробування та профілі безпеки після реалізації цільових змін.

2. Відомості про робочий процес та умови експлуатації

2.1. Опис бізнес-процесів (BPMN / FSM)

Поточні процеси IAS реалізовано спеціалізованими модулями та стійкими записами стану, а не рушієм BPE. Тому цей розділ фіксує лише фактичний процесний контур без приписування системі неіснуючих BPE-модулів або виконуваних BPMN-схем.

2.1.1. Поточний процесний контур

У наявній реалізації окремі доменні сценарії координуються кодом IAS і збереженим станом:

- імпорт OVPN виконує попередній аналіз конфігурації та формує доменні об'єкти без збереження приватного ключа;
- випуск сертифіката приймає та перевіряє CSR, взаємодіє з СА і зв'язує результат із пристроєм та профілем безпеки;
- майстер налаштування VPN веде стійку чернетку, перевіряє умови переходів і готовність матеріалів;
- передавання конфігурації формує канонічну команду з ревізією та контрольною сумою, доставляє її до VPN і зберігає результат;
- звіряння стану виявляє розбіжності, осиротілі записи та потребу у відновленні або виведенні з експлуатації.

Фактичні стани, переходи, умови, повторні спроби та помилки мають бути окремо відтворені як модель AS IS за кодом і тестами. Лише після цього керування процесом може бути поетапно перенесене на `synrc/bpmn/BPE`. У цільовій архітектурі BPE керує станами й переходами, а наявний майстер залишається користувацьким інтерфейсом над процесом.

2.1.2. Фактична модульна архітектура

Поточна реалізація поділена на веб-рівень, доменні служби, стійкі сховища та інтеграційні модулі. Веб-модулі не повинні містити криптографічну, транзакційну або мережеву логіку: вони приймають події користувача, викликають доменні служби та відображають результат.

Модуль або група модулів	Фактична відповідальність
<code>ias_provisioning_wizard.erl</code>	Веб-сторінка майстра: приймання подій, навігація між кроками та відображення стану. Не є авторитетним сховищем процесу.
<code>ias_provisioning_wizard_store.erl</code> , <code>ias_provisioning_wizard_draft_store.erl</code>	Створення, оновлення, відновлення та збереження чернетки майстра; вибір доменних об'єктів і виконання переходів між кроками.
<code>ias_provisioning_wizard_readiness.erl</code> , <code>ias_provisioning_wizard_relationships.erl</code> , <code>ias_provisioning_wizard_authorization.erl</code>	Перевірка готовності матеріалів, узгодженості графа зв'язків, сертифікатів і рішення про авторизацію перед передаванням конфігурації.

Модуль або група модулів	Фактична відповідальність
<code>ias_domain_store.erl</code>	Авторитетне стійке зберігання доменних об'єктів через KVS/Mnesia, перевірка схем і транзакційне оновлення проєкцій.
<code>ias_relationship_*</code>	Побудова, перевірка та відображення графа зв'язків між користувачами, пристроями, сертифікатами, профілями, політиками й VPN-сервісами.
<code>ias_csr_validation.erl</code> , <code>ias_certificate_verification.erl</code> , <code>ias_x509_validation.erl</code>	Перевірка CSR і X.509, зв'язування сертифікатного матеріалу з доменними об'єктами та формування результатів перевірки.
<code>ias_device_csr_enrollment.erl</code> , <code>ias_cmp_enrollment.erl</code>	Підготовка випуску сертифіката для пристрою та поточний перехідний СМР-шлях. <code>ias_cmp_enrollment.erl</code> поки запускає зовнішній OpenSSL і має бути замінений керованим клієнтом або адаптером СА.
<code>ias_ovpn_preview.erl</code> , <code>ias_ovpn_import.erl</code> , <code>ias_ovpn_provisioning.erl</code>	Аналіз OVPN, формування попереднього перегляду й доменної проєкції та підготовка керованого сценарію без збереження приватного ключа в IAS.
<code>ias_vpn_provisioning_command.erl</code> , <code>ias_vpn_provisioning_delivery.erl</code> , <code>ias_vpn_client.erl</code>	Формування канонічної команди, ревізії та контрольної суми, передавання до VPN через Erlang RPC і фіксація результату доставки.
<code>ias_vpn_reconciliation.erl</code> , <code>ias_vpn_orphan_recovery.erl</code> , <code>ias_vpn_recovery_manifest.erl</code>	Порівняння стану IAS і VPN, виявлення розбіжностей та осиротілих записів, планування й атомарне виконання відновлення.

Межі відповідальності є такими: KVS/Mnesia зберігає авторитетний стан IAS; СА випускає сертифікати; VPN застосовує передані команди та зберігає власний стан виконання; IAS координує процес, але не підміняє СА або VPN.

2.2. Опис ролей та прав доступу (ABAC)

Доступ до адміністративних функцій IAS обмежується на базі ABAC. Приклад правила авторизації:

```
allow(Operator, Action, Object) ->
    OperatorRole = maps:get(role, Operator),
    OperatorEDRPOU = maps:get(edrpou, Operator),
    ObjectSensitivity = maps:get(sensitivity_level, Object),

    IsSecurityAdmin = (OperatorRole == security_admin),
    MatchesEDRPOU = (OperatorEDRPOU == maps:get(edrpou, Object, undefined)),

    case {IsSecurityAdmin, ObjectSensitivity} of
        {true, _} -> true;
        {false, confidential} -> MatchesEDRPOU;
        {false, public} -> true;
        _ -> false
    end.
```

2.3. Умови експлуатації та системне середовище

Система IAS повинна розгортатися у кластерному середовищі:

- Операційна система: Linux (Ubuntu Server LTS, Rocky Linux) або macOS (для розробки).
- Платформа: Erlang/OTP версії 28+.
- Служби взаємодії: Розподілені Erlang-ноди, з'єднані за допомогою erpm та TLS mesh.
- Вимоги до СУБД: Mnesia, інтегрована через інтерфейс KVS.

3. Інформаційне та програмне забезпечення

3.1. Інформаційне забезпечення (Схеми та Дані)

3.1.1. Визначення структур даних (Erlang Records)

Всі ключові сутності описуються у вигляді Erlang рекорді:

```
-record(ias_domain_object, {
    key,                                % {Kind, ObjectId}
    schema_version = 1,                 % Версія схеми даних
    kind,                               % user | device | certificate | policy
    object_id,                          % Унікальний UUID
    payload = #{},                      % Мапа з атрибутами об'єкта
    revision = 1,                       % Номер поточної ревізії
    created_at = 0,                     % Timestamp створення
    updated_at = 0                      % Timestamp оновлення
}).

-record(ias_certificate_material_record, {
    key,                                % {SubjectKind, SubjectId}
    schema_version = 1,                 %
    subject_kind,                       % user | device | ca
    subject_id,                         % UUID суб'єкта
    material_type,                      % public_cert | cert_chain | signature
    encoding = pem,                     % pem | der
    source,                             % cmp | est | manual
    fingerprint_sha256,                % SHA256 відбиток сертифіката
    body_envelope = #{},                % Мапа, що містить PEM-тіло
    revision = 1,                       %
    created_at = 0,                     %
    updated_at = 0,                     %
    expires_at = undefined              % Термін дії сертифіката
}).

-record(ias_vpn_device_state, {
    device_id,                          % UUID пристрою (PK)
    schema_version = 2,                 %
    revision = 0,                       % Актуальна ревізія на шлюзі
    command_digest = undefined,         % Хеш останньої відправленої команди
    canonical_command = #{},            % Тіло сформованої команди
    binding = #{},                      % Параметри мережевої прив'язки
    lifecycle_state = unbound,          % unbound | pending | active | degraded
    last_decommission = undefined,      %
    decommission_history = [],           %
    decommissioned_at = undefined,      %
    updated_at = 0                      %
}).

-record(ias_csr_enrollment_record, {
    csr_fingerprint,                   % Хеш CSR (PK)
    schema_version = 1,                 %
}
```

```

    status = submitted,          % submitted | processing | signed | rejected
    retryable = false,          % Чи можна повторити спробу
    payload = #{},              % Мапа з параметрами запиту та CSR PEM
    revision = 1,
    created_at = 0,
    updated_at = 0
  }).

-record(ias_vpn_reconciliation_incident, {
  device_id,                    % UUID пристрою
  schema_version = 1,
  kind,                        % orphan | stale_revision | fingerprint_mismatch
  reason,                      % Текстовий опис розбіжності
  token,                       % Унікальний токен інциденту
  status = open,               % open | acknowledged | resolved
  snapshot = #{},              % Порівняльний знімок станів IAS та VPN
  first_seen = 0,
  last_seen = 0,
  occurrences = 1,
  acknowledged_by = undefined,
  acknowledged_note = undefined,
  acknowledged_at = undefined,
  resolved_by = undefined,
  resolved_note = undefined,
  resolved_at = undefined,
  updated_at = 0
}).

```

3.1.2. Опис довідників та реєстрових сутностей

Опис полів реєстрових сутностей (таких як **User**, **Device**, **Certificate**) відповідає таксономії, зазначеній у Технічних вимогах. Всі записи зберігаються у таблиці **Mnesia kvs**, яка містить записи типу **ias_domain_object** та інші допоміжні рекорди.

3.1.3. Алгоритми оцінки статусу довіри (Trust Evaluation)

Приклад визначення статусу пристрою на основі його криптографічного стану:

```

evaluate_device_trust(DeviceState, CertRecord, CurrentTime) ->
  case CertRecord#ias_certificate_material_record.expires_at of
    Expires when CurrentTime > Expires ->
      {blocked, expired};
    _ ->
      case check_crl_status(CertRecord#ias_certificate_material_record.fingerprint_sha256) of
        revoked -> {blocked, revoked};
        ok ->
          case DeviceState#ias_vpn_device_state.lifecycle_state of
            degraded -> {degraded, connection_timeout};
            active -> {ready, ok};
            unbound -> {incomplete, no_binding}
          end
        end
      end
    end.
end.

```

3.2. Програмне забезпечення (Реалізація)

3.2.1. Цільова інтеграція з ВРЕ

Виконувані ВРЕ-модулі для імпорту OVPN, випуску сертифікатів, оцінки довіри та передавання конфігурацій у поточному репозиторії відсутні. Техноробочий проєкт не повинен наводити для них вигаданий Erlang-код або назви модулів як частину реалізованої системи.

Після фіксації моделі AS IS може бути підготовлена цільова BPMN/ВРЕ-модель. Вона повинна повторно використовувати наявні доменні модулі як сервісні дії, зберігати перевірену поведінку та не переносити криптографічну або доменну логіку безпосередньо до визначення процесу.

3.2.2. Модулі перевірки CSR і сертифікатів

Окремого модуля `ias_validator.erl` у поточному репозиторії немає. Його вигаданий код не є частиною реалізації та вилучений із техноробочого проєкту. Фактичні обов'язки розподілено між такими модулями:

- `ias_csr_validation.erl` — синтаксична та структурна перевірка CSR;
- `ias_x509_validation.erl` — розбір і перевірка матеріалу X.509;
- `ias_certificate_verification.erl` — перевірка сертифіката у доменному контексті IAS;
- `ias_configured_ca_trust_anchor.erl` — отримання налаштованого якоря довіри СА;
- `ias_certificate_material_store.erl` — стійке зберігання публічного сертифікатного матеріалу та метаданих.

Приватні ключі пристроїв не передаються цим модулям і не зберігаються в IAS. Перевірка CRL/OCSP у режимі реального часу залишається цільовим станом до появи окремого реалізованого й протестованого адаптера.

4. Вимоги до засобу за ISO/IEC/IEEE 29148

4.1. Функціональні вимоги

Система повинна забезпечувати повнофункціональне керування ідентичностями, валідацію сертифікатів, оновлення конфігурацій шлюзів VPN без втрати з'єднань користувачів та виявлення невідповідностей стану мережі.

4.2. Вимоги до інтерфейсів та дизайну

- Веб-інтерфейс адміністративної консолі повинен базуватися на реактивному фреймворку N2O/NITRO.
- Відповідність вимогам WCAG 2.1 рівню AA для доступності інтерфейсів.
- Візуальний дизайн повинен наслідувати фірмовий стиль Zencrypted з підтримкою Sleek Dark Mode.

4.3. Вимоги до безпеки та захисту інформації

- Шифрування каналів зв'язку за допомогою TLS v1.3.
- Підтримка КЕП CAdES-X Long та алгоритму ДСТУ 4145-2002.
- Ізоляція ключів: приватний ключ ніколи не записується і не передається в IAS, залишаючись виключно на кінцевому пристрої.
- Атестація комплексу за вимогами ДССЗІ України на рівень захисту ГЗ.

4.4. Вимоги до продуктивності та надійності

- Час аптайму системи не менше 99.99% (High Availability).
- Час відновлення (RTO) після повного перезапуску ноди не більше 5 секунд завдяки KVS/Mnesia rehydration.
- Здатність обробляти до 1000 запитів авторизації на секунду на одну ноду.

4.5. Вимоги до логування та аудиту

- Всі операції провіренінгу, випуску та зміни статусів довіри повинні підписуватися цифровим підписом ноди та записуватися в стійкий лог аудиту.
- Заборона модифікації або видалення записів журналу аудиту (immutable audit log).

4.6. Адміністративні та юридичні вимоги

- Всі компоненти поставляються з ліцензіями відкритого вихідного коду (MIT/Apache 2.0).
- Модуль IAS повинен інтегруватися з наявною інфраструктурою підприємства без потреби закупівлі додаткового платного ПЗ.